

Chapter 6

Authentication and Access control

Password and Passphrase

- Both **passwords** and **passphrases** are used to verify your identity, but they rely on different strategies for security.
- **password** typically relies on **complexity** (special characters and numbers) in a short string
- **passphrase** relies on **length** and the use of multiple random words.

Feature	Password	Passphrase
Typical Length	8–12 characters	15+ characters (often 20+)
Structure	Short jumble of letters, numbers, and symbols	A sequence of several random words
Core Strength	Character complexity	Extreme length (entropy)
Memorability	Hard to remember; often written down	Easier to remember; maps to mental images

Biometrics

- Biometric authentication verifies a person's identity based on **who they are** using unique physiological or behavioral traits.
- Unlike passwords, these factors are inherently linked to the individual and are difficult to lose, share, or forget.

Physiological Biometrics

- These are based on stable physical measurements of the body:
- **Fingerprint Recognition:** Analyzes unique ridge and valley patterns on the fingertips. It is the most widely adopted and cost-effective method.
- **Palm Scan (Palm Print/Vein):** Maps the lines, creases, and textures of the entire palm or the unique blood vessel patterns (vein) beneath the skin. Vein patterns are considered more secure as they are subdermal.
- **Hand Geometry:** Measures the physical dimensions of the hand, including finger length, width, and thickness. It is often used for physical access control in workplaces.

- **Iris Scan:** Scans the complex, unique patterns in the colored ring of the eye. It is highly accurate and used in high-security environments like border control.
- **Facial Scan (Facial Recognition):** Uses 2D or 3D imaging to map facial geometry, such as the distance between eyes and nose shape.
- **Hand Topography:** Also known as **hand normalization**, this specialized process involves mapping the surface contours and global appearance of the hand to identify unique markers.

Behavioral Biometrics

- These focus on unique patterns in how a person acts or performs tasks:
- **Signature Dynamics:** Analyzes not just the final image, but the **process** of signing—including pressure, speed, stroke order, and rhythm.
- **Voice Print (Voice Recognition):** Identifies individuals by analyzing vocal characteristics like pitch, tone, cadence, and frequency.
- **Keystroke Dynamics:** (Related to "Hand Typography") Tracks a user's unique typing rhythm, speed, and patterns as they interact with a keyboard.

AAA Server

- AAA is a security framework used to control access to network resources and monitor user activity. AAA server acts as a centralized "bouncer" for the network.
- **Authentication (Who are you?):** Verifies a user's identity by comparing provided credentials (passwords, certificates, or biometrics) against a database.
- **Authorization (What can you do?):** Determines the specific permissions and resources an authenticated user is allowed to access (e.g., specific VLANs or folders).
- **Accounting (What did you do?):** Records the user's actions, such as login/logout times and data consumed, creating an audit trail for billing or security forensics.
- **Common Protocols:** [RADIUS](#) (widely used for Wi-Fi and VPNs) and **TACACS+** (primarily for managing network hardware like routers).

RADIUS (Remote Authentication Dial-In User Service)

- RADIUS is the "standard" for end-user network entry.
- **Performance:** Uses **UDP**, which is faster and has less overhead but is less reliable as it doesn't guarantee packet delivery.
- **Security:** It only encrypts the password field. The username and other attributes are sent in plaintext, which is vulnerable to snooping.
- **Bundle Approach:** It sends authentication and authorization information together in one step. When you are verified, you are simultaneously given your access rights.

TACACS+ (Terminal Access Controller Access-Control System Plus)

- TACACS+ is the "microscope" for administrative control over network infrastructure.
- **Reliability:** Uses **TCP**, providing a connection-oriented, reliable transmission that immediately notifies the admin if a server crashes.
- **Granular Authorization:** Because it separates the "AAA" functions, it can authorize **individual commands**. For example, a junior admin might be allowed to run show commands but blocked from configure terminal.
- **Stronger Encryption:** It encrypts the entire payload, including the username and the specific commands being sent, making it much harder to intercept sensitive administrative activity.

Key Comparison

Feature	RADIUS	TACACS+
Primary Use	Network Access (Wi-Fi, VPN)	Device Admin (Routers, Switches)
Protocol	UDP (Ports 1812/1813)	TCP (Port 49)
Encryption	Encrypts only the password	Encrypts the entire packet
AAA Separation	Combines Auth & Authz	Separates all three functions
Standard	Open Standard (Multi-vendor)	Cisco Proprietary (mostly)

- TACACS+ is the gold standard for managing the network devices themselves because it allows for granular control over individual commands.

Enter configuration mode

```
switch# configure terminal
```

Enable AAA framework

```
switch(config)# aaa new-model
```

Define the TACACS+ server address and shared secret

```
switch(config)# tacacs-server host 192.168.1.50 key MySharedSecret
```

Create an authentication list named 'ADMIN-AUTH'

It tries TACACS+ first; if the server is down, it fails over to the local database

```
switch(config)# aaa authentication login ADMIN-AUTH group tacacs+ local
```

Apply this authentication list to the remote login lines (SSH/Telnet)

```
switch(config)# line vty 0 15
```

```
switch(config-line)# login authentication ADMIN-AUTH
```

What are VTY (Virtual Teletype) Lines?

- Unlike physical ports (like Console or Ethernet), VTY lines are software-defined. They allow multiple administrators to connect to the device simultaneously over the network.

What do the numbers 0 15 mean?

- The numbers represent the **range** of simultaneous connections the device will allow.
- 0 is the first connection.
- 15 is the sixteenth connection.
- By specifying 0 15, you are applying your security settings to all **16 possible concurrent sessions** at once.

- RADIUS is typically used for broad user access, such as authenticating Wi-Fi users or VPN connections.
- # Enable AAA framework
- router(config)# aaa new-model
- # Define the RADIUS server and shared secret
- # Note: RADIUS uses separate ports for authentication (1812) and accounting (1813)
- router(config)# radius-server host 10.0.0.100 auth-port 1812 acct-port 1813 key RadiusSecret
- # Create a default authentication list for logins
- router(config)# aaa authentication login default group radius local
- # Optional: Configure the console to use this RADIUS authentication
- router(config)# line console 0
- router(config-line)# login authentication default

Smart Cards vs. Memory Cards

- Both are physical tokens used for "something you have" authentication, but they differ significantly in intelligence.
- **Memory Cards:** These are simple storage devices (like an SD card) that hold data but have no processing power. They are often used for low-security applications like prepaid phone cards or gym passes.
- **Smart Cards:** These contain an embedded **microprocessor chip** that can actively process data and perform cryptographic operations.
 - **Security:** They can store and protect private keys that never leave the card itself.
 - **Usage:** Commonly used for corporate ID badges, credit cards (EMV), and high-security government access.

3. Kerberos

- Kerberos is a network authentication protocol designed to provide strong security over insecure networks like the internet.
 - It is famous for being the default authentication method for [Microsoft Active Directory](#).
- **The "Ticketing" System:** Instead of sending your password across the network, Kerberos uses **tickets** to prove identity.
 - **Authentication Server (AS):** You log in once and receive a **Ticket Granting Ticket (TGT)**.
 - **Ticket Granting Server (TGS):** You exchange your TGT for a "service ticket" to access a specific resource (like a printer or file share).

Cont..

Kerberos ...Cont

- **Mutual Authentication:** Both the user and the server must prove their identity to each other, preventing "man-in-the-middle" attacks.
- **Time-Sensitive:** Tickets include timestamps and usually expire after 8–10 hours to minimize the window for attackers to reuse stolen session data

Access control

- Access control models define the **rules** that determine how users (subjects) interact with resources (objects) like files, databases, or networks.

1. Discretionary Access Control (DAC)

- In DAC, the **owner** of the resource has total control over who else can access it.
- **How it works:** If you create a file, you decide the permissions (Read, Write, Execute) for other users.
- **Key Feature:** High flexibility and user-driven.
- **Example:** Standard **Windows or macOS file sharing** where you right-click a folder to "Share with" a specific person.
- **Risk:** It is the least secure model because users can accidentally (or intentionally) grant overly broad permissions to others.
-

2. Mandatory Access Control (MAC)

- MAC is the strictest model, where access is determined by a **central authority** (like a System Admin) based on security labels.
- **How it works:** Users and resources are assigned specific security levels (e.g., **Top Secret, Secret, Unclassified**). A user can only access a resource if their "clearance" matches or exceeds the resource's "classification" label.
- **Key Feature:** The end-user **cannot** change permissions on their own files.
- **Example: Military and government systems** or SELinux (Security-Enhanced Linux).
- **Risk:** It is rigid and difficult to manage in fast-moving commercial environments.

3. Role-Based Access Control (RBAC)

- RBAC assigns permissions to **roles** rather than individual users. Users gain access by being assigned to a specific role.
- **How it works:** Permissions are tied to job functions (e.g., "Manager," "Accountant," "IT Support").
 - When a new employee joins the Accounting team, they are simply added to the "Accountant" role and automatically get all necessary access.
- **Key Feature:** Simplifies administration and follows the **Principle of Least Privilege**.
- **Example:** An **HR portal** where all employees can see their own pay stubs, but only those in the "HR Manager" role can see everyone's salary data.
- **Risk:** Can lead to "role explosion" if a company creates too many specific sub-roles.

lab exercise:

- demonstrates how a single computer uses **Role-Based Access Control (RBAC)** to manage multiple users. Instead of assigning permissions to each person, you will assign them to "Groups" (Roles).

Lab Objective

- Create a **Junior Admin** role and a **Standard User** role on a single device, then verify that their permissions are strictly controlled by their assigned roles.

4. **Attribute-Based Access Control (ABAC)**

- is a highly flexible security model that grants access based on a combination of characteristics called **attributes**.
- Unlike RBAC, which only asks "What is your role?", ABAC evaluates the context of every request in real time using four types of attributes:

1. **Environmental Attributes (The "Where" and "When")**

- These are the situational variables you mentioned. They add a layer of safety by ensuring access only happens under secure conditions.
- **Time of Day:** Access is only allowed during business hours (e.g., 9:00 AM – 5:00 PM).

Cont..

1. Environmental Attributes (The "Where" and "When")

- **Location/Geography:** Access is restricted to specific IP ranges, office buildings, or even entire countries to comply with data residency laws like GDPR.
- **Device Health:** Only allows access if the user is on a company-managed laptop with up-to-date antivirus.

2. Subject Attributes (The "Who")

- These describe the person or system making the request, often pulled from an HR database or Active Directory.
- **Examples:** Department (Finance), Security Clearance (Top Secret), Job Title, or Project Assignment.

3. Object Attributes (The "What")

- These describe the resource being accessed.
- **Examples:** File sensitivity (Confidential), Data owner, or Document type (e.g., medical record vs. public report).

4. Action Attributes (The "How")

- These define what the user wants to do with the resource.
- **Examples:** Read, Write, Delete, Approve, or Download.